

CREDIT RISK MANAGEMENT

AUDIT PROGRAM #13-10-00

The release of this audit program to parties external to IBM requires the written approval of the Chief Auditor.

This program is intended as a guide for assessing risk management in this process through the performance of an audit or a similar engagement. Risk management is the process to identify, manage, and control potential events in order to provide reasonable assurance related to the achievement of IBM's business and control objectives. IBM's control objectives fall into five broad categories:

1. compliance with external laws and regulations, as well as IBM policies and procedures
2. accomplishment of business objectives
3. reliable information for financial reporting and decision making
4. efficient operations, and
5. safeguarding both intellectual and physical assets.

The control assessment questions are intended to address process objectives from the categories above and the risks to achieving those objectives. Objectives and risks in the actual process under review may differ based on organizational, operational, regulatory, and economic factors. As such, individuals performing the engagement must formulate a test strategy based on risks relative to the actual process under review, regardless of whether the risks are identified within this program.

DATE CHANGED	SECTION #	SUBTITLE IN SECTION	CHANGED BY (NAME)	COMMENTS
September 2025	Planning	Audit Program Risk Alignment	CA&AS Ops	Changes to audit risk levels from recent revalidation
February 2023	All	All	CA&AS	Converted from Notes into a Word document and into a Box folder

CREDIT RISK MANAGEMENT

AUDIT PROGRAM #13-10-00

Table of Contents

PROCESS AND OBJECTIVE	3
PLANNING: Audit Program Risk Alignment.....	4
PLANNING: Data Analysis.....	5
PLANNING: Reference Material	6
PLANNING: Fraud Template.....	7
CONTROL ASSESSMENT QUESTIONS	8
Key Control Question: 1. Credit Evaluations - Client and Commercial Financing.....	8
Primary Test: Credit Evaluation (CE001.P)	9
Key Control Question: 2. Credit Evaluations - New Business Partners	11
Credit Evaluation of New Vendor/Business Partner/ Sponsored Vendors (CV001.P)	12
3. Restructured Credit Arrangements for High-Risk End Customers, Dealers, or Suppliers.....	13
Restructured Credit Arrangements for High-Risk Customers or Commercial Businesses (RC001.P) .	14
Key Control Question: 4. System Controls, Access Management, and Separation of Duties.....	15
Primary Test: System Controls, Access Management, and Separation of Duties (SC001.P)	16
Key Control Question: 5. Special Handling Process	17
Primary Test: Special Handling Process (SH001.P).....	18
Key Control Question: 6. Business Continuity Planning.....	19
Secondary Test: Business Continuity Planning (BC001.S)	20
Key Control Question: 7. Credit Risk Management Reports.....	23
Primary Test: Credit Risk Management Reports (CR001.P)	24

CREDIT RISK MANAGEMENT

AUDIT PROGRAM #13-10-00

PROCESS AND OBJECTIVE

The credit evaluation process involves more than just IBM Global Financing (IGF) IBM Credit LLC (IBM Credit) assessing the credit risk of a potential customer. IGF relies on Dun and Bradstreet to obtain critical information about customers, such as bankruptcies, financial statements, non-financial measurements, potential for being a fraudulent customer, and if the customer actually engaged in a fraud. The credit department within IGF, is staffed by personnel who have expertise in specific industries, such as insurance and manufacturing. Not every leasing/loan contract, commonly referred to as a "deal", is reviewed by a credit analyst. If certain criteria are met, the credit evaluation could be performed automatically with no intervention by the credit analyst.

In IBM Global Financing there are two distinct processes to evaluate credit. One is for end user (customer) financing and the other is for commercial (dealer /supplier) financing. End customers typically finance information technology to use for their own purposes, whereas commercial financing involves the purchase of goods for subsequent resale. Also, end customers are defined as either an end-user or a business partner who needs to finance products or services.

The end customer is defined to be more than an IBM customer seeking financing to obtain IBM products or services. The end customer could be a business partner who needs to finance IBM or non-IBM products/services for subsequent resale. Also, the actual credit investigation may involve more than just the end customer who takes possession of the products. There is a one-time credit evaluation performed on new business partners. There have been frauds involving business partners who arranged for fraudulent financing agreements with end customers for non-IBM content. In addition to evaluating the end customers credit position, it is also necessary to validate that the business partner has not engaged in prior fraudulent dealings as reported by Dun and Bradstreet in this one-time evaluation. Also, if IGF approved credit to an end customer and the business partner matched the profile for having the potential to commit fraudulent acts as defined and reported by Dun and Bradstreet, it is essential for IGF to document an ensure appropriate management approval before signing the contracts.

The process to obtain credit begins when an end customer, needs to finance hardware, software, or services from IBM Global Financing. The content of the items financed could be purchased from IBM or purchased directly from a third party. Once a decision is made to finance, the end customer through IBM marketing or an IBM authorized business partner approaches IGF for either a loan or a lease. IGF performs a credit evaluation on the end customer and the business partner if the business partner is new. In order to make that determination, the services of Dun and Bradstreet as well as other sources are used. Once all the variables have been considered, a credit rating (1 through 7) is assigned, and that concludes the credit organization's role in the process. Subsequent to the evaluation by credit, financing rates will be determined by the pricing organization in IGF. IGF will commit to a rate even though the end customer still has the option to competitively bid the financing agreement. Once the end customer and IGF decide to do business, the financing agreement is signed, and the lease/loan payments begin when the end customer attests that the goods or services have been received. The document used to attest to the receipt of the products or services is referred to as a certificate of acceptance (COA).

Starting 1Q 2017, separate financing legal entities under IBM Credit LLC ("IBM Credit") were set up in each country in which IGF operates, specifically for client financing, commercial financing and credit risk management related activities. In addition, IBM Credit will begin separate financial reporting, including 10-Q and 10-K filings, whilst its financial results will continue to roll up into IBM financial statements. New processes were implemented to facilitate the inter-company agreements, inter-company billings, and services provided between IBM and IBM Credit. Also, existing processes were modified to reflect to the operational changes.

Please note that only Client Financing and Commercial Financing activities are run by IBM Credit*, while GARS remained with IBM.

* Note: Taiwan, Macau, Argentina, Ecuador, Uruguay not in IBM Credit LLC

CREDIT RISK MANAGEMENT

AUDIT PROGRAM #13-10-00

PLANNING: Audit Program Risk Alignment

Credit Risk Management

Defined Risk Area	Audit Risk Level	Key Control Question	Test Number
Credit Evaluation	High	Credit Evaluations - Client and Commercial Financing Credit Evaluations - New Business Partners	CE001.P CV001.P
Restructured Credit Arrangement	Medium	Restructured Credit Arrangements for High-Risk End Customers, Dealers, or Suppliers	RC001.P
Collateral Management	Low		
Account Monitoring	Low	Special Handling Process	SH001.P

CREDIT RISK MANAGEMENT AUDIT PROGRAM #13-10-00

PLANNING: Data Analysis

Data analysis should be a part of every engagement where data is available in databases or data warehouses that can be accessed through query programs. This concept enhances the risk-based auditing approach, makes the audit process more efficient, and increases the productivity of the audit team. When the audit team does not have the skills required to perform these tasks, assistance should be sought from the Technology team.

All data used for analysis must be reconciled to an independent source so that the auditor has confidence that the universe is complete.

The [Data Analysis engagement procedures in the Audit Manual](#) (link internal to CA&AS members only) provide further suggestions.

This table shows what data can be reviewed and analysis techniques.

Data to be Analyzed	Analysis to be Performed	Possible Anomalies	Concern
Autoscore with Aged Accounts Receivable	Compare the Autoscore deals with Aged Accounts Receivable.	System approved credits for clients without good credit standing	Risk of doing business with clients without good credit standing
List of repositories used by the credit team	Request the Technology team to validate that the access rights granted to the users of the repository is on a need-to-know basis and not provided to all users.	System access incorrectly granted to users who do not have a business need to view data used in assessing credit such as third-party financial statements.	Unauthorized access to SBI (sensitive business information)
System Generated Universes obtained in the IDR for Credit Evaluations (PON, purchases, services, COF, and CF)	Perform a completeness check on the universes provided.	Inaccurate or incomplete universes.	Downstream processes such as management reporting, KCFR testing, daily activity reports impacted adversely
Repositories	Request Business Intelligence and Analytics team to perform a scan of the repositories.	Open repositories with exposed IBM confidential information.	Data exposure

CREDIT RISK MANAGEMENT AUDIT PROGRAM #13-10-00

PLANNING: Reference Material

Updated Credit Directives to be provided by client in the IDR

IBM Global Financing U.S. Procedures Manual

EMEA Global Financing Policy and Guidance Database

Accounting Practices: <https://w3.ibm.com/w3publisher/accounting-policy-financial-reporting>

- AP LEASE – Accounting for Leases

Corporate Instructions can be found at the following web site: <http://w3-03.ibm.com/ibm/documents/corpdocweb.nsf/ContentDocsByTitle/Corporate+Directives>

- CIO104 Information Technology Security
- CIO122 IBM Worldwide Records Management
- CIO129 Business Transformation Management System
- FIN151 Application Systems Control and Auditability (ASCA)
- FIN166 Risk Evaluation - Corporate Directive Deviation
- FIN183 Separation of Duties
- LEG116 Classification and Control of IBM Information

CREDIT RISK MANAGEMENT

AUDIT PROGRAM #13-10-00

PLANNING: Fraud Template

Fraud is any intentional act or omission designed to deceive others and resulting in the victim suffering a loss and/or the perpetrator achieving a gain. Fraud can be categorized into fraudulent financial reporting, misappropriation of assets, and improper or unauthorized expenditures.

Description of Fraud Risk	Typical Controls that should Detect the Fraud Risk	Testing Approach
Fraud: misrepresentation of financial strength by the credit requester High in emerging markets due to limited availability of quality external credit and financial information	1. Customer and business partner validations 2. Credit and payment history 3. Audited financial statements	Test credit approval and compliance to Ts and Cs. Test aged / delinquent AR, write offs, special handling cases for look back for root cause existence at deal origination. Test Credit and deal review approvals for OEM and unsecured financing.
Fraud: Financing fictitious clients, assets, assets not backed by intrinsic value or inflated assets, or assets not accepted by clients	1. Customer and business partner validations 2. Supplier's invoice 3. Certificate of acceptance of client's receipt of the goods	Test credit approval and compliance to Ts and Cs. Test BP approval, validation of payment to suppliers, BP sourced deals, lease inception (certificate of acceptance).

Note: The probability and impact will vary depending on the organization/business unit that is being audited.

CREDIT RISK MANAGEMENT

AUDIT PROGRAM #13-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Credit Evaluations - Client and Commercial Financing

Objective:

Did the credit evaluation process ensure that financing risk was effectively managed, and credit decisions were properly supported?

Risk/Exposure:

Sound credit evaluation is critical in ensuring that the end customer, dealer or supplier has the ability to pay their outstanding balances. If sound credit evaluation practices are not followed, the end customer, dealer or supplier may default on the lease/loan resulting in a loss of assets to IBM.

Note: With the setup of IBM Credit as a separate entity starting 1Q 2017, IBM will be setup as a supplier for Client Financing (for deals where IBM Credit is financing IBM transactions) and Commercial Financing. However, the credit assessment for IBM is exempted at the global level.

CREDIT RISK MANAGEMENT

AUDIT PROGRAM #13-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Credit Evaluations - Client and Commercial Financing

Primary Test: Credit Evaluation (CE001.P)

Objective:

Did the credit evaluation process ensure that financing risk was effectively managed, and credit decisions were properly supported?

Approach:

Select a risk-based sample of end customers and dealers or suppliers and test for the following attributes. (Consider obtaining GCAT access for ease in reviewing artefacts)

Also note that in some geographies, the customer number in the evaluation extracts from GCS (Credit Tool) are not the same as the customer numbers in the AR files. Consider clarifying with the client if there is a way to map the 2 universes.

For credit approvals performed by credit analysts validate that:

1. Was separation of duties enforced? (Credit should be approved by persons who would not receive any benefit, such as compensation, from the sale. Examples include marketing or financial marketing analysts' personnel.)
2. If end customers or dealers or suppliers were exempt from a credit evaluation, was the exemption documented and reasonable?
3. Were required external and internal financial statements used for credit evaluations?
4. Was a consistent method of evaluating credit risk applied to each credit decision?
 - a. As part of the credit evaluation, was there adequate validation as to what is being financed? Was there adequate understanding of what IBM is financing prior to approval?
 - b. As part of the credit evaluation, was there adequate validation as to who is being financed?
5.
 - a. Were Dun and Bradstreet (or alternative) services fully utilized in the analysis of the credit evaluation that was performed by IBM Global Financing. Examples include Fraud Scoring (looking for companies that have the potential for engaging in fraudulent activity), Severe Risk database (companies that have actually committed a fraudulent act, bankruptcies, etc. the financial model and non-financial model maintained by Dun and Bradstreet. Also, select an additional sample of companies that did not pass the fraud scoring or severe risk database criteria (as published by Dun and Bradstreet), and if credit was approved, was the exception properly documented and approved?
 - b. If the lease or loan to the end customer was a result of a business partner arranged deal, was the business partner properly recognized as an IBM business partner?
6. Were all contractual obligations fulfilled by the end customer, dealer or supplier prior to credit being approved? For example, direct debit authorization from a customer or remarketer with a poor credit rating.
 - a. Was the documentation from end customer, dealer or supplier supporting the credit decision reviewed and current?
 - b. Was there adequate documentation to support all credit decisions, especially if an analyst deviated from the normal process?

CREDIT RISK MANAGEMENT

AUDIT PROGRAM #13-10-00

CONTROL ASSESSMENT QUESTIONS

Control Question: 1. Credit Evaluations - Client and Commercial Financing

Primary Test: Credit Evaluation (CE001.P)

(Continued)

7. Were credit limits enforced and exceptions properly documented and approved? Also, were all credit delegation letters, policies and guidelines clear and compliance enforced.
8. For commercial financing only:
 - a. Were under secured or undercollateralized loans properly approved?
 - b. Was the fair market value of the collateral properly established and investigated to ensure there were no other lines on the collateral?
 - c. Did an independent party validate that the collateral existed?
9. Do procedures adequately describe what the process is for issuing credit?
10. For credit approvals that were automatic, with no credit analyst involvement, validate that:
 - a. All the correct procedures were properly adhered to and the end customer, dealer or supplier actually qualified for an automatic credit evaluation.
 - b. The parameters in the system for determining credit risk were properly approved and any changes were also properly approved.
 - c. Any exceptions were properly approved.
 - d. For deals that were automatically approved and subsequently resulted in uncollected receivables, was there a lookback process to revisit the auto approval process?
11. For any end customers, dealers or suppliers that were exempt from credit checking, select a sample and determine if valid reasons were in place to grant exemption.
12. Determine if controls were effective to prevent end customers, dealers or suppliers from being added to a list where there would be no credit evaluation.
13. Select a sample of end customers and dealers or suppliers who went bankrupt and determine if a proper initial credit evaluation was performed.
14. Was the Accounts Receivable balance considered at the time of evaluation accurate?
15. Determine the process governing the validation of collaterals. Example: in AP, standby letters of credit are validated by Credit and irrevocable letters of credit are validated by BSO.

NOTE: The risk-based sample must include high risk end customers and dealers or suppliers (Credit Score of 4, 5, 6 or 7), high dollar leases/loans, leases/loans with collateral, and leases/loans to customers arranged by a business partner.

Review policy for granting credit and validate that: Is approved credit available for a defined period of time? (Request procedures - Higher risk end customers and dealers or suppliers should be reevaluated more frequently than low risk customers).

CREDIT RISK MANAGEMENT AUDIT PROGRAM #13-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Credit Evaluations - New Business Partners

Objective:

Did the credit evaluation process for new business partners ensure that financing risk was effectively managed, and credit decisions were properly supported?

Risk/Exposure:

Sound credit evaluation is critical in ensuring that the business partner (one time evaluation) is credible before conducting business on IBM's behalf. If sound credit evaluation practices are not followed, the business partners intentions may be in conflict with IBM's best interest.

CREDIT RISK MANAGEMENT

AUDIT PROGRAM #13-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Credit Evaluations - New Business Partners

Credit Evaluation of New Vendor/Business Partner/ Sponsored Vendors (CV001.P)

Objective:

Determine if the credit position of new business partners has been properly evaluated.

Approach:

Obtain a list of new suppliers including vendor, IBM Business Partners, IGF Financing Associates, or Sponsored Vendors and test for the following:

- A. Was a consistent method of evaluating credit risk applied to each credit decision?
- B. Were Dun and Bradstreet services fully utilized in the analysis of the business partner credit evaluation that was performed by IBM Credit. Examples include Fraud Scoring (looking for companies that have the potential for engaging in fraudulent activity), Severe Risk database (companies that have actually committed a fraudulent act, bankruptcies, etc., the financial model and non-financial model maintained by Dun and Bradstreet. Also, select an additional sample of companies that did not pass the fraud scoring or severe risk database criteria (as published by Dun and Bradstreet), and if the business partner was subsequently authorized to conduct business on IBM's behalf, was the exception properly documented and approved?
- C. Was Business Partner Organization (BPO) involved in the selection and evaluation of new business partners? Verify the existence and adherence to the IGF Worldwide Business Partner - Client Financing process.
- D. Was separation of duties enforced? (Credit should be approved by persons who would not receive any benefit, such as compensation, from the sale. Examples include marketing or financial marketing analysts' personnel.)
- E. Was there adequate and current documentation to support all credit decisions, especially if an analyst deviated from the normal process?
- F. Do procedures adequately describe what the process is for evaluating business partners?

Please refer to Credit Evaluation CE001.P for further testing information

Note: With the setup of IBM Credit as separate entity, validate the Intercompany Services Agreement between IBM and IBM Credit was established for credit evaluation service performed by IBM Credit. Also, validate the inter-company cost of the service were being charged on a timely basis as per the Intercompany Services Agreement.

CREDIT RISK MANAGEMENT AUDIT PROGRAM #13-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question:

3. Restructured Credit Arrangements for High-Risk End Customers, Dealers, or Suppliers

Objective:

Determine if the end customer, dealer or supplier is in compliance with the terms and conditions as specified in the restructured credit agreement.

Risk/Exposure:

Failure to closely monitor high risk end customers, dealers or suppliers who did not comply with the original credit agreement could lead to a further loss of IBM assets.

CREDIT RISK MANAGEMENT

AUDIT PROGRAM #13-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question:

3. Restructured Credit Arrangements for High-Risk End Customers, Dealers, or Suppliers

Primary Test:

Restructured Credit Arrangements for High-Risk Customers or Commercial Businesses (RC001.P)

Objective:

Determine if the end customer, dealer, or supplier is in compliance with the terms and conditions as specified in the revised credit agreement.

Approach:

Obtain a list of end customers, dealers or suppliers who defaulted on their original credit agreement and test for the following:

1. Evidence of close monitoring by key personnel and management.
2. End customer, dealer or supplier is making payments in accordance with the contract as defined in the restructured credit agreement.
3. Has the end customer, dealer or supplier fulfilled all the obligations in the contract?
4. Were any exceptions to the restructured credit agreement properly evaluated and approved?
5. Were restructured agreements submitted to the appropriate entry point contact referenced in the T's & C's deviations document (T's & C's deviations document can be viewed in the 'reference material' section of the audit program)?
6. Were the restructured terms subsequently reviewed and approved by appropriate personnel?

Note: Consider testing this scope together with Special Handling Process (SH001.P) as some of the testing attributes might be overlapping and high-risk customers could be considered as focus account under the Special Handling Process.

CREDIT RISK MANAGEMENT AUDIT PROGRAM #13-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. System Controls, Access Management, and Separation of Duties

Objective:

Were there adequate controls over the system to evaluate credit enforced to prevent unauthorized entry.

Risk/Exposure:

Inadequate system controls could lead to credit being approved to fraudulent companies that could default on the lease or loan. As a result, IBM may not be able to collect outstanding accounts receivables.

CREDIT RISK MANAGEMENT

AUDIT PROGRAM #13-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. System Controls, Access Management, and Separation of Duties

Primary Test: System Controls, Access Management, and Separation of Duties (SC001.P)

Objective:

Determine if there were adequate controls over the global credit system (GCS) to prevent unauthorized entry and that separation of duties was enforced.

Approach:

1. Request a separation of duties assessment that lists all IGF credit personal and their job responsibilities. Also, request the system access and system descriptions for the credit system. Compare the job responsibilities to the allowed system access for each employee and determine if there are any potential separation of duties conflicts.
2. Test the process used to grant and revoke access to GCS. Does the process require appropriate approval and business justification in order to gain access to the system? Does the process provide for the removal of access once a user's business needs no longer require access to GCS?
3. Request the most recent system access revalidation. Was the revalidation successful in identifying all users and were all users access without business need removed from the system? Was it all properly documented?
4. Request the quarterly review. Was the review successful in ensuring the removal of user-IDs and access capabilities of individuals no longer in the employ of IGF Credit?
5. Were confidential IBM information contained in several credit risk assessment database, maintained to be accessible to individuals on a need-to-know basis?
6. Were there shared userids and were there processes in place to revalidate and monitor such.
7. Were accesses to external websites, such as Dun and Bradstreet and other references, managed in accordance with IBM data security guidelines.
8. Were system controls in place to ensure that systems used (such as GCS) present the credit request amount accurately?

CREDIT RISK MANAGEMENT AUDIT PROGRAM #13-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Special Handling Process

Objective:

To determine the adequacy of focus account and lessons learned process.

Risk/Exposure:

Inadequate focus account and lessons learned process could lead to inability of management to analyze the circumstances that lead to a loss and specify how the loss might have been avoided or minimized.

CREDIT RISK MANAGEMENT

AUDIT PROGRAM #13-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Special Handling Process

Primary Test: Special Handling Process (SH001.P)

Objective:

To determine the adequacy of focus account and lessons learned process.

Approach:

1. Was there a focus account process established to review the list of accounts to be focused on based on exposure and financial strength?
2. Was there adequate compliance to the global focus process (includes watchlist accounts process, early warning signal checklist process)?
3. Was there a lessons learned process established to analyze the circumstances that lead to a loss and to specify how the loss might have been avoided or minimized?
4. Obtain a list of watchlist customers and test for the following:
 - Account was identified as troubled in a timely manner
 - Calculations supporting the exposure and forecasted minimum loss were accurate and supported by business justification
 - Required management reviews of the cases occurred, including approvals
 - Defined follow-up actions were performed, and in a timely manner
 - Reserves were requested and booked in a timely and accurate manner
 - Write-offs were timely and appropriately booked
 - Lessons learnt process was executed and action plan was monitored for completion
 - Other functions were properly involved to handle the case (i.e., Legal)
 - Account was properly communicated as watch list case to credit analysts, to avoid further exposure
5. Obtain a list of focus accounts and test for the following:
 - Account was properly highlighted as potential for review
 - Factsheet was completed
 - Early warning analysis properly was performed with corresponding score/color and case was referred to special handling (if applicable)
 - Management review and sign-off occurred with the required frequency
 - Follow-up actions were defined, and monitored to completion

Note: The Mainline business could make use of the Special Handling information to generate the list of Cash on Delivery customers and Stop Ship customers.

Note: Certain risk factors that can be identified in the Account Receivable process can also be tested as part of the Special Handling Process (SH001.P) as Account Receivable is one of the factors considered for a client to be listed as focus account in the Special Handling Process.

CREDIT RISK MANAGEMENT

AUDIT PROGRAM #13-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Business Continuity Planning

Objective:

To determine if process owners have developed, reviewed, and tested business continuity plans (BCP) so that in the event of natural or man-made disasters, pre-defined plans can be executed to maintain business operations.

Risk/Exposure:

Any material disruption of business operations due to natural or man-made disasters can lead to significant financial loss not only to IBM but potentially also for IBM's customers. Many business processes have been centralized, and often operations are conducted in locations which may be susceptible to business disruption. As a result, it is important that business and process owners have developed plans to maintain continuity of business operations in those centralized operations.

CREDIT RISK MANAGEMENT

AUDIT PROGRAM #13-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Business Continuity Planning

Secondary Test: Business Continuity Planning (BC001.S)

Note: Business continuity risks become increasingly important in the environment where there are centers of excellence and multiple countries are supported by one center. This should therefore be an important test and considered primary in that environment. IT testing for disaster recovery is handled by the IT audit teams.

You should refer to BPBC127 Guideline for Business Process - Area Business Continuity Planning in the reference section of this audit program, in support of your review.

Objective:

To determine if process owners have developed, reviewed, and tested business continuity plans (BCP) so that in the event of natural or man-made disasters, pre-defined plans can be executed to maintain business operations.

Approach:

A guideline has been put in place for process owners providing guidance on business continuity planning (BCP). It should be noted by the audit team that this is a guideline rather than a specific instruction. However, it will act as a guide for you to understand whether key risks have adequately been considered for BCP and enable you to make an informed judgement regarding the risk mitigation in place. Different processes will have their own unique risk profiles regarding the probability and impact of an interruption to business operations. For example, the probability and impact of a business interruption for a process which has been centralized for multiple countries in a location with less-developed infrastructure is likely greater than that of a process supporting only a single country in location with robust infrastructure. As such, auditor judgment will be required to determine how important BCP is for a particular process, as well as to determine the reasonableness of any plans that have been designed by the process owners.

In the initial data request information ask for the process owner to confirm what plans have been implemented to ensure business continuity in the event of a natural or man-made disaster. Review that non-I/T process elements have been adequately considered in the BCP.

The following list of questions has been designed based on the BPBC127 Guideline for Business Process - Area Business Continuity Planning:

1. Has management assessed the risk to business continuity (BC) and identified the key business processes and activities that require formal business continuity planning based on impact to the business.
 - Identification and prioritization of business processes' activities in addition to prioritization done through by the Enterprise Process Owner (level 3 plans).
 - Understanding and documentation of the potential impact (financial, operational and reputation) to IBM from business disruptions from uncontrolled, non-specific events.
 - Identification of the legal and regulatory requirements for the institution's business functions and processes.
 - Review and approval from senior management.

CREDIT RISK MANAGEMENT

AUDIT PROGRAM #13-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Business Continuity Planning

Secondary Test: Business Continuity Planning (BC001.S)

(Continued)

2. For critical business areas and processes, has the maximum acceptable outage (MAO) been established and considered in the BC plan?
 - Estimation of maximum allowable outage (MAO), based on the “acceptable level” of losses, associated with the institution’s business functions and processes.
 - Estimation of recovery time objectives (RTOs), recovery point objectives (RPOs), and Maximum Tolerable Downtime (MTD) of applications and supporting technology required for business operations.
 - If applicable, recommended critical path recovery order.
 - Reconciled with agreed IT recovery priorities (Business Criticality Values, RTO/MTD).
3. For business areas and processes where there is a business continuity risk, has the BC Plan been created, reviewed, and approved by management?
 - The organization shall establish documented procedures for responding to a disruptive incident and how it will continue or recover its activities within a predetermined timeframe.
 - Top management shall review the organization’s BCMS, at planned intervals, to ensure its continuing suitability, adequacy and effectiveness.
4. Does the Plan document the specific continuity and recovery actions for all four impact scenarios (workforce, workplace, IT, and regional) that will need to take place to mitigate risk to the business if the impact lasts longer than the documented business’ maximum acceptable outage?
 - Flexible to respond to unanticipated threat scenarios and changing internal conditions.
 - Focused on the impact of various threats that could potentially disrupt operations rather than on specific events.
 - Effective in minimizing service disruptions and financial loss through the implementation of mitigation strategies.
5. Does the BC plan clearly identify dependencies such as site resources, IT, suppliers, process interdependencies, partners, non-IT services and been reviewed and synchronized with the appropriate crisis management team?
 - An effective BCP coordinates across its many components, identifies potential process or system dependencies, and mitigates the risks from interdependencies.
6. Is there an established, management-endorsed business continuity team to oversee the maintenance, invocation, and execution of the BC plan?
 - Defined roles and responsibilities for people and teams having authority throughout an incident.
 - Additional teams as necessary to facilitate recovery execution per the chosen strategy.
7. Are personnel aware and educated on the plan, strategy, and roles?
 - Business continuity training should be an integral part of the BCM.
 - Comprehensive training program should be developed for all employees, conducted at least annually, and kept up to date to ensure that everyone understands their current role in the overall recovery process.
 - An audit trail should be maintained to document management's training efforts.

CREDIT RISK MANAGEMENT

AUDIT PROGRAM #13-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Business Continuity Planning

Secondary Test: Business Continuity Planning (BC001.S)

(Continued)

8. Is there a regularly executed process for validating the Plan through tests including key elements such as people, technology (data, systems, applications, and telecommunications), and locations that house staff and technology to ensure fit for purpose and alignment with current risks?
- Tests should be based on appropriate scenarios that are well planned with clearly defined aims and objectives that promote continual improvement.
 - Produce formalized post-exercise reports that contain outcomes, recommendations and actions to implement improvements and are reviewed with management.
 - Tests are conducted at planned intervals and when there are significant changes within the organization or to the environment in which it operates.
9. FOR COMMERCIAL CONTRACTS: Where IBM has customer contracts including business continuity planning, have BC plans been implemented in accordance with contractual obligations?

FOR CUSTOMERS WITH REGULATORY REQUIREMENTS: Does the plan accommodate and account for the any unique rigor or accommodations for the regulatory body.

- Adherence with contractual obligations contained in the IBM Responsibilities section of the Schedule or similar agreement. Including communication, recovery parameters, specialized technical designs.
- Special considerations to meet unique regulatory requirements (HIPAA – US Healthcare has unique wording on backup, protection, and availability of data).

CREDIT RISK MANAGEMENT AUDIT PROGRAM #13-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 7. Credit Risk Management Reports

Objective:

To determine the adequacy of controls within the credit risk management process through the use of management reports such as daily activity reports (DAR).

Risk/Exposure:

Inadequate controls within the credit risk management process such as inaccuracies in management reports (e.g., DAR) could lead to undetected credit evaluation misses.

CREDIT RISK MANAGEMENT AUDIT PROGRAM #13-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 7. Credit Risk Management Reports

Primary Test: Credit Risk Management Reports (CR001.P)

Objective:

To determine the adequacy of controls within the credit risk management process through the use of management reports such as daily activity reports (DAR).

Approach:

1. Were DAR's complete and accurate?
2. Were universes used for management reports complete and accurate?
3. Were lessons learned included in the reviews by management?